

Narrativa Explicativa GQM + PRAGMATIC

De los grandes objetivos de país al último log de servidor

1. El problema de siempre: números sin propósito, propósitos sin números

Durante años se han multiplicado en España los planes, estrategias y comunicados solemnes sobre ciberseguridad.[web:21][web:27][web:56] En paralelo, también han proliferado los indicadores: incidentes, centros de ciberseguridad, millones invertidos, gráficos con flechas hacia arriba.

Lo que no siempre ha proliferado es la coherencia entre unos y otros.

- Se miden cosas porque es fácil medirlas, no porque respondan a preguntas importantes.
- Se formulan objetivos tan generales que ningún dato real parece afectarlos.
- Y entre los dos extremos, el técnico y el político se miran como si hablaran idiomas distintos.

2. GQM: empezar por el principio (el objetivo)

El enfoque Goal–Question–Metric viene precisamente a poner orden en esa conversación.[web:45][web:46][web:51]

1. Goal (Objetivo): no “tener más ciberseguridad”, sino “reducir el tiempo medio de recuperación de servicios esenciales tras incidentes graves”, “aumentar el porcentaje de operadores que hacen modelado de amenazas en diseño”, etc.
2. Question (Pregunta): qué necesitamos saber para saber si nos acercamos o nos alejamos de ese objetivo.
3. Metric (Métrica): qué dato concreto (número, ratio, tendencia) puede responder a la pregunta sin rodeos.

Esto obliga a hacer algo radicalmente sencillo y, por ello mismo, raro: decidir para qué se quiere medir antes de decidir qué se va a medir.

3. PRAGMATIC: no todas las métricas merecen vivir

Incluso con GQM, la fauna de métricas posibles es inmensa. Es ahí donde entra PRAGMATIC, el “meta-método” que permite evaluar si una métrica vale la pena.[web:50][web:52][web:58]

Cada métrica se somete a nueve criterios:

- ¿Predice algo útil o sólo describe el pasado?
- ¿Es relevante para nuestros objetivos o sólo curiosa?
- ¿Nos lleva a decisiones accionables o no sabremos qué hacer con ella?
- ¿Es genuina y significativa o está viciada por sesgos y maquillaje?
- ¿La podemos medir con precisión razonable, de forma oportuna y sin arruinarnos en el intento?

Las puntuaciones PRAGMATIC son, en el fondo, un antídoto contra la tentación de coleccionar métricas como cromos.

4. El caso PASTA+STRIDE a escala país

En el informe PASTA se identificaron indicadores estructurales: cobertura del modelado de amenazas, incidentes por categoría STRIDE, madurez de ejercicios de simulación, tiempos de recuperación y grado de integración con la gestión de riesgo y el ROI.[web:18][web:21][web:31]

Aplicar GQM y PRAGMATIC sobre estos indicadores permite:

- Vincularlos explícitamente a objetivos nacionales (proteger infraestructuras, aumentar madurez, mejorar resiliencia, optimizar inversión).
- Depurar las métricas para quedarse con las que realmente merecen un sitio en el cuadro de mando.
- Identificar dónde necesitamos mejores datos (por ejemplo, en incidentes STRIDE y tiempos de recuperación) y dónde bastan encuestas bien hechas (cobertura de Threat Modeling, uso en ROI).

5. Un ejemplo en carne viva: MTTR crítico

Cuando se habla del “tiempo medio de recuperación de servicios esenciales tras incidentes graves” (MTTR crítico), nadie discute su importancia.[web:21] Es una métrica:

- Evidentemente relevante (¿cuánto tiempo estamos a oscuras, sin agua, sin servicios sanitarios?).
- Políticamente significativa (aparece en titulares).
- Accionable (se pueden fijar objetivos, SLAs, planes de inversión).

Al pasarla por PRAGMATIC, vemos también su lado oscuro: medirla bien es caro, requiere coordinación y sistemas de registro consentidos, y es sensible a lo que se considera “incident grave”. Aun así, su puntuación global es alta: merece estar en el núcleo duro de métricas nacionales.

Frente a ella, otras métricas quizá resultan más baratas pero menos significativas; o muy bonitas en informes, pero con escaso poder predictivo.

6. Del país a la organización (y vuelta)

El mismo marco GQM+PRAGMATIC puede aplicarse dentro de una empresa o administración:

- Objetivo: “Reducir en un 30 % el riesgo anual de interrupción de nuestro servicio digital X en 3 años”.
- Preguntas: “¿Cuántas amenazas relevantes se han identificado y tratado?”, “¿Cuál es nuestro MTTR específico?”, “¿Qué cambios hemos implementado tras simulaciones?”.
- Métricas: las mismas familias (M1–M5), pero aterrizadas al perímetro concreto.

El beneficio de usar el mismo lenguaje desde el nivel nacional hasta el de proyecto es obvio: las conversaciones dejan de ser una traducción apresurada y se convierten en una continuidad de escalas.

7. Una invitación razonablemente irónica

En vez de añadir más indicadores a la lista interminable, el marco propone hacer algo más valiente:

- Reconocer que muchas métricas actuales puntuarían bajo en PRAGMATIC.
- Retirar sin remordimientos las que no aportan valor.
- Concentrar el esfuerzo en unas pocas métricas que sí ayudan a tomar decisiones, justificar inversiones y rendir cuentas de manera seria.

Al final, de eso va la ciberseguridad a escala país: menos fuegos artificiales y más datos que conecten, sin trucos de magia, al ciudadano que no quiere ver su servicio cortado con el ingeniero que ajusta un firewall y el ministro que firma un presupuesto.